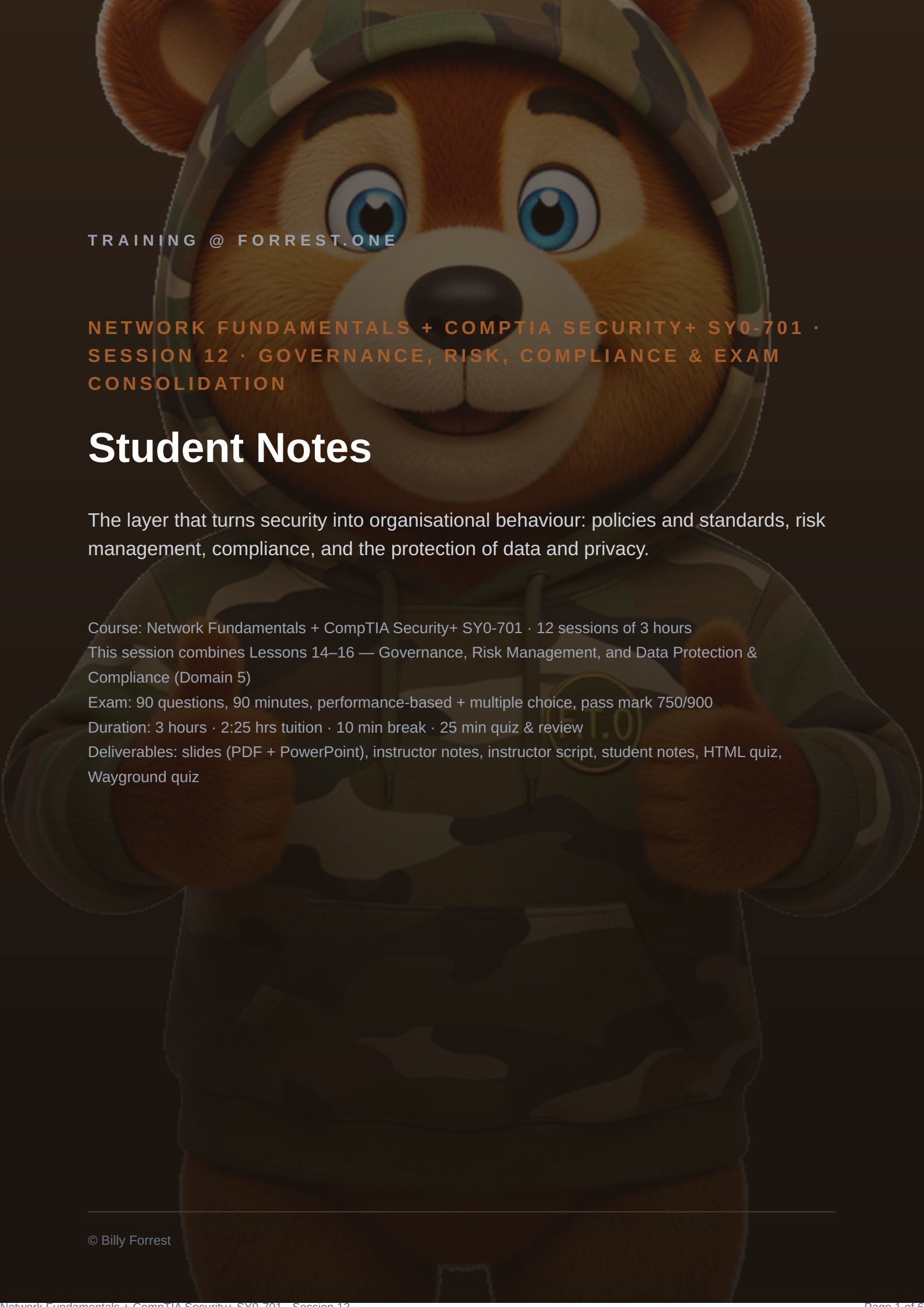




TRAINING @ FORREST.ONE

**NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 12 · GOVERNANCE, RISK, COMPLIANCE & EXAM
CONSOLIDATION**

Student Notes

The layer that turns security into organisational behaviour: policies and standards, risk management, compliance, and the protection of data and privacy.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session combines Lessons 14–16 — Governance, Risk Management, and Data Protection & Compliance (Domain 5)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Governance, Risk, Compliance & Awareness

Your revision guide for Session 12, the course finale (Lessons 14 to 16 · Domain 5, Security Program Management and Oversight, 20% of the exam). Six chapters take you from why governance exists, through external obligations and risk management, to vendors, compliance, audit and the awareness programme, and then close with the exam consolidation. Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready.

Key terms

Term	Definition
Governance	Direction, rules and accountability for security, aligned to business objectives
Authority	The documented power to decide, approve or authorise
Accountability	Answering for the outcome, reinforced by audits
Policy	High-level statement of management intent
Standard	Mandatory, specific and measurable requirement
Guideline	Recommended practice, not mandatory
Procedure	Step-by-step instructions for a task
Regulatory requirement	A mandatory obligation from a regulator or the law (HIPAA, PCI DSS, GDPR)
Risk identification	Asset inventory, threat modelling and vulnerability assessment
Likelihood / impact	Probability of the event / scale of the consequence
Qualitative risk	Ratings and judgement: high, medium, low
Quantitative risk	Monetary values: SLE and ALE
Exposure factor	The share of the asset value lost if the risk occurs
Annual rate of occurrence	Expected frequency of the event each year
Risk register	Living record of risks, ratings, owners and treatment status
Risk appetite	How much risk the organisation will pursue or retain
Risk tolerance	How far it may drift from that appetite before action

Term	Definition
The four responses	Avoid, transfer, mitigate, accept
Business impact analysis	Identifies critical processes and drives recovery priorities
Rules of engagement	The boundaries of what a vendor may access and do
Compliance	Adhering to the laws and standards that apply to you
Attestation	A formal declaration that controls meet stated criteria: SOC 1, SOC 2, SOC 3
Internal / external audit	Own staff for self assessment / independent third party for assurance
Awareness programme	Audience analysis, objectives, content, delivery, measurement
Data classification	Public, internal, confidential, restricted
Data owner / steward / custodian	Accountable / governance / implementation
GDPR / UK GDPR	EU and UK data protection frameworks
Data sovereignty	Data is subject to the law where it resides

Core concepts

Chapter 1: Governance Foundations

Governance comes first because it aligns security with business objectives, stops security being implemented in isolation, targets spending at what the business depends on, and sets the risk appetite. Structure matters: a cross-functional security committee, reporting lines that reach the chief executive or the board, and executive oversight that supplies direction, resources and review. Authority is the documented power to decide; accountability is answering for the outcome. Executive roles are the chief information security officer, security directors and the board. Operational roles are analyst, administrator and architect, with data ownership split between the accountable owner and the implementing custodian. The four document types form a hierarchy: policy (intent), standard (mandatory and measurable), guideline (recommended), procedure (the steps). Every document is developed, approved, distributed and reviewed.

Chapter 2: External Obligations and Risk Identification

Requirements arrive from regulators, contracts and the law, and external obligations become internal policy. Regulatory: HIPAA, PCI DSS, NERC CIP, GDPR and CCPA, each targeting a sector or region. Contractual: service level agreements, data processing agreements and partnership agreements, with the NIST Cybersecurity Framework as a common baseline. Legal: liability, due diligence, jurisdiction and privacy law. Risk identification uses the asset inventory, threat modelling and vulnerability assessment, because you cannot manage a risk you have never named. Assessment sits on two axes: likelihood and impact, expressed either qualitatively (ratings) or quantitatively (money and probabilities), and usually as a hybrid.

Chapter 3: Risk Analysis, Registers and Treatment

The calculation: single loss expectancy is asset value times exposure factor; annualised loss expectancy is single loss expectancy times the annual rate of occurrence. With an asset value of 100,000, an exposure factor of 40 percent and a rate of 0.1, that gives an SLE of 40,000 and an ALE of 4,000 a year. Every risk goes into a register that describes it, rates it, names an owner and tracks treatment status. Appetite is how much risk the organisation will pursue or retain; tolerance is how far it may drift from that appetite. The four responses are avoid, transfer, mitigate and accept, and acceptance is always a documented management decision.

Chapter 4: Risk Reporting, Business Impact and Vendors

Reporting is tailored by audience: technical detail for teams, business consequences for executives, compliance and plain language for the board and regulators, with dashboards, detailed reports and executive summaries as the formats. A business impact analysis identifies critical processes, maps dependencies, assesses consequences and drives recovery priorities and resource allocation. Vendor risk starts before the contract: questionnaire, documentation review, on site assessment, due diligence, with depth matched to risk. Contracts carry data handling, incident notification, audit rights, security-based service levels and an exit clause. Monitoring continues afterwards, with compliance verification, performance tracking and clear rules of engagement under least privilege.

Chapter 5: Compliance, Privacy and Audit

Compliance means adhering to the laws and standards that apply to you, and it is proved with evidence. Frameworks have territory: PCI DSS for cardholder data, HIPAA for medical information, SOX for financial reporting, GDPR for personal data of EU citizens. Monitoring is continuous, using a security information and event management system and configuration management, with manual review for interpretation, and logs and audit trails as the evidence. Non-compliance costs money, permission, trust and legal liability, with penalties up to four percent of global turnover or twenty million euro. Privacy law adds subject rights, informed consent and breach notification. Audits are internal (self assessment) or external (independent assurance), and both follow planning, evidence, findings and remediation tracking.

Chapter 6: Assurance, Testing and Awareness

Attestation is a formal declaration that controls meet stated criteria: SOC 1 for financial reporting controls, SOC 2 for security, availability, processing integrity, confidentiality and privacy, SOC 3 as a high-level summary. Penetration testing actively proves the controls, in black box, white box or grey box form, with scope agreed first and findings remediated and retested. An awareness programme starts with audience analysis, sets specific, measurable and time bound objectives, uses current and recognisable content, delivers by role, and measures with assessments, simulations and reported incidents. Phishing training teaches recognition and one reporting route, then simulates with progressive difficulty, immediate feedback and reasonable pacing.

Data protection and exam consolidation

Classification is public, internal, confidential and restricted, with the higher class receiving stronger protection, and three states, at rest, in transit and in use. Roles: owner accountable, steward governing, custodian implementing. The lifecycle runs collect, store, use, share, archive, destroy, with retention policy and secure

destruction at the end. GDPR and UK GDPR supply principles, rights, informed consent and the breach notification duty; sovereignty means data answers to the law of the jurisdiction where it resides, with GDPR and CCPA applying by data-subject location.

Practical cautions

- Do not confuse policy (intent) with standard (requirements), or standard with guideline (advisory).
- Do not treat guidelines as mandatory.
- Do not confuse authority (the power to decide) with accountability (answering for the outcome).
- Do not treat appetite and tolerance as the same idea.
- Do not accept risk without management sign-off and documentation.
- Do not write the risk register once and file it away; it is a living document.
- Do not let the contract end the vendor relationship, because monitoring continues after signature.
- Do not treat attestation as proof; penetration testing is what tests.
- Do not run so many phishing simulations that fatigue destroys the reporting habit.
- Do not keep data beyond retention, and do not treat deletion as secure destruction.
- Do not ignore which jurisdiction your cloud data lives in.
- Do not swap the data owner (accountable) with the custodian (implementer).
- Do not treat compliance as the whole of security; go beyond the baseline.

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz. This session's quiz is the final one, so treat a low score as a map of what to revise rather than a verdict.

Exam tips for Session 12

- The exam pairs: policy and standard, standard and guideline, appetite and tolerance, qualitative and quantitative, owner and custodian, internal and external audit, avoid and accept.
- Risk response questions are scenario-based, so match the response to the situation rather than to the wording.
- Expect quantitative items that supply asset value, exposure factor and annual rate of occurrence and ask for SLE or ALE.
- Vendor items test the lifecycle: assess before contract, monitor during, exit cleanly.
- Compliance items test which framework applies, judged by industry, geography and data type.
- Audit items test who conducts the audit and what each type is for.
- Attestation items test the SOC report types and what penetration testing adds.

- Awareness items test programme design and measurement, not just phishing recognition.
- GDPR items: principles, consent, rights, the breach notification window and the penalties.
- Data roles: owner accountable, custodian implements, never reversed.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, Domain 5.
- ICO guidance on UK GDPR principles, rights and breach notification.
- NIST SP 800-30, risk assessment guidance, and NIST SP 800-39 for risk management.
- NIST Cybersecurity Framework, the common contractual baseline named in vendor agreements.